

Durcissement du contrôleur de domaine Lyon-DC (192.168.1.40)

Durcissement système Debian

Gestion des privilèges

- Suppression de l'accès sudo sans mot de passe.
- Modification du fichier `/etc/sudoers.d/90-cloud-init-users`.
- Vérification des privilèges sudo des comptes locaux.

Avant :

```
debian ALL=(ALL) NOPASSWD:ALL
```

Après :

```
debian ALL=(ALL:ALL) ALL
```

Sécurisation SSH

Configuration appliquée :

```
PermitRootLogin no
PasswordAuthentication yes
MaxAuthTries 3
LoginGraceTime 30
```

Mesures obtenues :

- Interdiction de connexion SSH du compte root.
- Limitation des tentatives d'authentification.
- Réduction du risque de bruteforce.

Protection contre les attaques par force brute

Installation et configuration de Fail2ban.

Protection active :

- Surveillance des connexions SSH.
- Bannissement automatique après plusieurs échecs.
- Réduction du risque d'attaque automatisée.

Mises à jour automatiques

Installation et activation :

```
unattended-upgrades
```

Objectif :

- Installation automatique des correctifs de sécurité.

Désactivation IPv6

Configuration :

```
net.ipv6.conf.all.disable_ipv6 = 1  
net.ipv6.conf.default.disable_ipv6 = 1
```

Objectif :

- Réduction de la surface d'attaque.
 - Simplification de l'administration du laboratoire.
-

Audit de sécurité

Vérification des comptes interactifs

Comptes identifiés :

```
root  
debian  
gns3
```

Résultat :

- Aucun compte anormal.
- Compte gns3 sans privilèges administrateur.

Vérification des privilèges sudo

Contrôle réalisé :

```
sudo -l
```

Résultat :

- Suppression du NOPASSWD.
- Élévation de privilège soumise à authentification.

Vérification des binaires SUID

Contrôle réalisé :

```
find / -perm -4000 -type f
```

Résultat :

- Aucun binaire suspect détecté.
- Uniquement des binaires système légitimes.

Vérification des binaires SGID

Contrôle réalisé :

```
find / -perm -2000 -type f
```

Résultat :

- Aucun binaire anormal détecté.

Vérification des services exposés

Contrôle réalisé :

```
sudo ss -tulpn
```

Ports identifiés :

```
53 DNS
88 Kerberos
135 RPC
139 SMB
389 LDAP
445 SMB
464 Kerberos
636 LDAPS
3268 Global Catalog
3269 Global Catalog SSL
22 SSH
```

Résultat :

- Ensemble cohérent avec un contrôleur de domaine Samba Active Directory.
-

Durcissement Active Directory

Politique de mots de passe

Configuration finale :

```
Password complexity: on
Store plaintext passwords: off
Password history length: 24
Minimum password length: 12
Minimum password age: 1 jour
Maximum password age: 90 jours
Account lockout threshold: 5 tentatives
Account lockout duration: 30 minutes
Reset account lockout after: 30 minutes
```

Mesures obtenues :

- Complexité obligatoire.
- Longueur minimale renforcée.
- Historique de mots de passe.
- Verrouillage automatique des comptes.
- Protection contre les attaques par bruteforce.

Services Active Directory validés

- DNS Samba opérationnel.
- Kerberos opérationnel.
- LDAP opérationnel.
- Contrôleur de domaine Samba fonctionnel.
- Résolution DNS du domaine ONGARDE.LOCAL validée.
- Authentification Kerberos validée.